

PLATEFORME DE CYBERSÉCURITÉ UNIFIÉE

CyberRadar

Voir, détecter, répondre et prouver — dans une seule plateforme, conçue pour les exigences du Royaume.

25

domaines de sécurité couverts

1

chaîne continue, de l'événement à la preuve

5

référentiels, dont la DNSSI et la loi 09-08

0

flux sortant nécessaire : vos données restent chez vous

Le problème n'est plus de voir. Il est de relier.

Un établissement financier marocain exploite aujourd'hui entre quatre et huit outils de sécurité, chacun excellent dans son domaine, aucun ne parlant au suivant.

L'information se perd aux jointures

Le SIEM détecte, l'analyste recopie dans l'outil de ticketing, l'ingénieur réseau applique le blocage à la main, et l'auditeur reconstitue la chronologie six mois plus tard à partir de trois exports.

Personne ne tient le chiffre

Chaque outil mesure son propre délai. Aucun ne mesure celui qui compte : le temps écoulé entre l'intrusion et le confinement effectif.

La conformité est un travail séparé

Les contrôles DNSSI, PCI DSS ou SWIFT se démontrent à partir de captures d'écran et de tableurs, reconstitués à chaque audit.

Le coût réel n'est pas le prix des licences. C'est le délai de réaction, les équivalents temps plein consacrés à la recopie, et l'impossibilité de répondre simplement à « montrez-moi ».

Une plateforme, pas une suite

Vingt-cinq domaines de sécurité partagent le même inventaire d'actifs, le même modèle d'identité, le même journal d'audit et le même référentiel de conformité. Ce ne sont pas des produits intégrés après coup : c'est un seul produit.

Voir

Ingestion, inventaire, exposition externe, graphe de connaissance

Détecter

SIEM, analyse comportementale, renseignement, chemins d'attaque

Répondre

Automatisation, réponse à incident, action réseau et applicative

Prouver

Journal d'audit, conformité, risque, gouvernance des accès

Un actif compromis est le même objet pour le moteur de détection, pour l'analyse de risque, pour le contrôle de conformité et pour le journal d'audit. C'est ce partage qui permet la phrase que personne ne peut écrire avec quatre outils : « **cette alerte, sur cet actif, a déclenché cette action, et voici la preuve** ».

Vingt-cinq domaines, sept familles

Socle

Multi-client · Identité, MFA, habilitations · Journal d'audit · Notifications

Visibilité

Ingestion syslog et API · Inventaire d'actifs · Surface d'exposition externe · Graphe de connaissance

Détection

SIEM et XDR · Analyse comportementale · Renseignement sur la menace · Chemins d'attaque

Réponse

Automatisation et playbooks · Réponse à incident · Sécurité réseau · Pare-feu d'API

Exposition

Vulnérabilités · Posture cloud · Posture des données · Chaîne logicielle · Mobile · Systèmes industriels

Gouvernance

Conformité réglementaire · Registre des risques · Gouvernance des accès · Comptes à privilèges · Fuite de données · Fraude

Pilotage

Tableaux de bord et indicateurs · Assistant d'investigation en langage naturel

Une organisation n'active pas les vingt-cinq le premier jour. Le socle, la visibilité et la détection constituent le démarrage naturel ; le reste s'ouvre sans nouvelle installation, parce que c'est la même plateforme.

La chaîne continue, de l'événement à la preuve

Six passages, et c'est à ces six endroits qu'un ensemble d'outils perd l'information.

1 · INGESTION Le journal arrive syslog, API, normalisation	2 · DÉTECTION La règle correspond corrélation, seuils, UEBA	3 · QUALIFICATION Le cas est ouvert alerte enrichie du contexte d'actif	4 · DÉCISION Le playbook s'applique manuel ou automatique	5 · ACTION L'adresse est bloquée politique réseau, compte, session	6 · PREUVE L'audit nomme l'auteur playbook, acteur, ressource, horodatage
---	--	--	--	---	---

Le chiffre qu'aucun outil isolé ne produit

Le délai entre la première tentative et le confinement effectif, mesuré étape par étape. C'est la réponse à la question d'un régulateur, et c'est le seul indicateur qu'une direction générale puisse suivre.

Mesuré en continu, pas une fois

Ce parcours s'exécute automatiquement à chaque modification du produit, contre une plateforme réelle. Une rupture entre deux étapes arrête la livraison.

Le parcours d'un événement

ÉTAPE	CE QUI SE PASSE	CE QUE CELA APPORTE
Collecte	Journaux syslog (RFC 3164, RFC 5424, CEF) ou appels d'API	Une seule porte d'entrée, quel que soit l'équipement
Normalisation	Traduction vers une taxonomie unique : acteur, action, actif, résultat	Une règle écrite une fois s'applique à toutes les sources
Enrichissement	Géolocalisation, correspondance avec les indicateurs connus, score de risque	La décision tient compte du contexte, pas seulement du journal
Corrélation	Règles à seuil et à fenêtre, comptage partagé entre répliques	Une attaque lente et répartie reste détectée
Qualification	L'alerte porte l'actif, sa criticité, son exposition et ses dépendances	L'analyste décide sans ouvrir trois autres outils
Action et trace	Playbook exécuté contre les API réelles, puis journal d'audit	Ce qui a été fait est opposable

L'enrichissement a lieu **avant** la détection, et non à côté. Un indicateur reconnu au moment de l'ingestion influence la règle ; reconnu après, il n'aurait rien changé.

Conçue pour durer et pour s'exploiter

Go

services compilés, empreinte mémoire basse, pas de machine virtuelle à régler

Kafka

bus d'événements : une coupure ne fait pas perdre la détection

2

bases : PostgreSQL pour l'état, ClickHouse pour l'historique volumineux

REST

tout ce que fait l'interface passe par une API documentée

Chaque domaine est indépendant

Un domaine se met à jour, redémarre ou monte en charge sans toucher aux autres. Une panne reste locale.

Rien n'est perdu en silence

File d'attente de rejet, reprise automatique après coupure du bus, reprise des événements arrivés pendant un redémarrage.

Observable

Traces distribuées, métriques exportables vers vos outils de supervision, journaux structurés.

Vos données restent où vous les mettez

- **Hébergement de votre choix.** Vos serveurs, votre centre de données, un hébergeur marocain. La plateforme n'appelle aucun service extérieur pour fonctionner.
- **Aucun flux sortant nécessaire au fonctionnement.** Pas de télémétrie, pas d'envoi de journaux vers un éditeur, pas de licence à valider en ligne. Un seul composant du produit appelle l'extérieur, et il est optionnel.
- **Transferts hors du Royaume maîtrisés.** La loi 09-08 impose une autorisation préalable de la CNDP. La plateforme n'en crée aucun de son fait.

Pourquoi c'est un sujet ici

La plupart des plateformes de sécurité modernes sont des services hébergés à l'étranger : vos journaux d'authentification, vos adresses internes et votre cartographie d'actifs y transitent par construction. Pour un établissement soumis à la DNSSI, c'est une question qui se pose avant toute discussion technique.

Les deux exceptions, et ce qu'elles valent

L'assistant d'investigation s'appuie sur un modèle externe : il se désactive, et la plateforme fonctionne entièrement sans lui. **Les livraisons de contenu de détection** arrivent par un canal signé — comme une mise à jour logicielle, à votre rythme, et le paquet s'installe aussi depuis un fichier.

Une plateforme de sécurité est jugée d'abord sur la sienne

- **Cloisonnement multi-client strict.** Chaque écriture vérifie que l'objet visé appartient bien à l'organisation appelante, avant d'écrire.
- **Habilitations appliquées à l'exécution.** Chaque opération exige une permission nommée, résolue depuis les rôles de la personne — pas un masquage de bouton dans l'interface.
- **Jetons à signature asymétrique.** La clé privée n'existe que dans le service qui émet. Aucun secret partagé entre composants.
- **Les actions automatiques sont tracées.** Un pare-feu modifié par un playbook laisse une trace nommant le playbook, l'automate et la ressource. Un robot n'agit pas anonymement.
- **Double authentification.** TOTP, et des comptes de service distincts des comptes de personnes.
- **Dépendances surveillées en continu.** Une vulnérabilité connue dans une bibliothèque arrête la livraison ; les dérogations sont datées et expirent d'elles-mêmes.

Ces points ne sont pas déclaratifs : chacun est tenu par des tests exécutés à chaque modification, et nous pouvons les montrer.

Les référentiels qui obligent au Maroc

RÉFÉRENTIEL	PORTÉE
DNSSI Directive Nationale de la Sécurité des Systèmes d'Information — DGSSI	Infrastructures d'importance vitale
Loi 09-08 Protection des données à caractère personnel — CNDP	Données personnelles, transferts hors du Royaume
PCI DSS 4.0 Industrie des cartes de paiement	Monétique, réseau de distributeurs
SWIFT CSP Customer Security Controls Framework	Paielements internationaux
ISO/IEC 27001:2022 Management de la sécurité de l'information	Transverse

Un contrôle relié à des actifs réels
Un contrôle ne porte pas une case à cocher : il porte les actifs concernés, un score, et la preuve qui l'étaye. L'écart se lit, il ne se reconstitue pas.

Le référentiel que vous apportez
Un référentiel interne, sectoriel ou imposé par un correspondant s'enregistre comme les cinq autres. La liste n'est pas fermée.

DORA n'y figure pas : c'est un règlement européen, qui n'oblige pas un établissement de droit marocain. Nous présentons ce qui s'applique ici.

Trois questions, trois réponses

« Sommes-nous exposés ? »

Une cartographie unique : les actifs, leur criticité métier, leur exposition, et les chemins qu'un attaquant peut emprunter pour atteindre le cœur bancaire. Une seule page, pas un rapprochement de tableurs.

« Combien de temps pour réagir ? »

Le délai entre la première tentative et le confinement effectif, mesuré de bout en bout. C'est l'indicateur qu'un conseil d'administration peut suivre, et celui qu'un régulateur demande.

« Sommes-nous en règle ? »

L'état des contrôles DNSSI, loi 09-08, PCI DSS et SWIFT, relié aux actifs réels et à leur preuve. L'audit se prépare en continu, pas en trois semaines avant la visite.

Ce que cela change dans l'organisation : une équipe de sécurité passe un temps considérable à recopier d'un outil à l'autre. Ce temps revient à l'analyse. C'est le gain le plus concret, et le plus difficile à obtenir autrement.

Exploitable par une équipe réelle

- **Installation en une commande.** Conteneurs ou binaires. Infrastructure, schéma, contenu, identités, services : des étapes séparables, chacune reprenant où elle s'est arrêtée.
- **Mises à jour sans interruption de service.** Le schéma évolue par migrations versionnées, appliquées une seule fois, sur une base en production — sans la détruire.
- **Pas de dépendance propriétaire.** PostgreSQL, Kafka, Redis, ClickHouse : des briques connues, que vos équipes savent exploiter et sauvegarder.
- **Supervision par vos outils.** Métriques Prometheus, traces OpenTelemetry, journaux structurés : la plateforme s'intègre à votre supervision, elle ne la remplace pas.
- **Montée en charge par domaine.** Le domaine qui sature se double, sans toucher aux autres. Les compteurs sont partagés, donc deux instances comptent ensemble.
- **Un contrôle avant mise en service.** Une commande vérifie magasins, schéma, services, données et la chaîne complète, puis rend un verdict.

Dimensionnement d'un démarrage : une machine de huit cœurs et trente-deux gigaoctets porte l'ensemble pour un pilote. La croissance se fait par domaine, pas par refonte.

Du signal à la preuve, sans rupture

Détection

Règles à seuil et à fenêtre, analyse comportementale par profil, correspondance avec les indicateurs connus **avant** la décision. Couverture ATT&CK lisible, et l'écart de couverture assumé plutôt que masqué.

Réponse

Playbooks exécutés contre les API réelles : blocage d'adresse, désactivation de compte, isolement d'actif, ouverture de cas. Manuels ou automatiques, avec le même niveau de trace.

Preuve

Un journal d'audit qui nomme l'auteur de chaque action — personne ou automate — la ressource touchée et le résultat. C'est ce qui transforme « nous avons réagi » en élément opposable.

Le catalogue de détection vous appartient

La plateforme livre un catalogue de détections signé. Vous adoptez celles qui vous conviennent, vous les ajustez, et **l'écart par rapport au standard reste tracé** : c'est ce que vous défendez devant un auditeur qui demande pourquoi un seuil est à trois et non à cinq.

Les seuils sont les vôtres

Seuils comportementaux, délais de remédiation par criticité, pondérations des chemins d'attaque : paramétrables par votre équipe, sans livraison de code et sans nous.

Une plateforme à intégrer, pas une boîte noire

455

routes d'API documentées : tout ce que fait l'interface, vous pouvez le faire

22

chapitres de documentation, dont une référence d'API générée depuis le code

0

fonction réservée à l'éditeur : il n'y a pas d'API privée

1

commande pour vérifier une installation avant de la livrer

Ce que vous déployez

Une installation conteneurisée, des identifiants générés, des clés de signature propres au client. Le durcissement est scripté et dit ce qu'il ne fait pas.

Ce que vous branchez

Les sources du client par syslog ou par API. Les comptes de service obtiennent leurs jetons par échange d'identifiants, avec les permissions de leur rôle et rien de plus.

Ce que vous pouvez vendre

Vos propres détections, signées de votre clé et livrées à vos clients par le même mécanisme que les nôtres. Le format et l'outil de validation sont documentés.

La couverture de détection est un objet, pas une promesse

Chez la plupart des éditeurs, les règles sont dans le produit : les faire évoluer demande une montée de version.

CATALOGUE Des détections versionnées des fichiers, pas du code	SIGNATURE Paquet signé empreinte vérifiable	PUBLICATION Canal indépendant rotation et révocation des clés	ADOPTION Vous prenez ce qui convient et vous l'ajustez	GÉNÉALOGIE L'écart reste tracé et défendable en audit
--	---	---	--	---

Ce que cela permet

Une nouvelle famille d'attaque est couverte par une livraison de contenu, en heures, sans toucher à la plateforme ni planifier une fenêtre de maintenance.

Et pour un intégrateur

Une offre de contenu propre : vos détections sectorielles, signées, livrées à votre parc de clients indépendamment de nos versions.

Ce qui relève de la politique de sécurité ne doit pas être dans le code

DÉCISION	QUI LA PREND	COMMENT
À partir de combien de tentatives un compte est-il suspect ?	Le RSSI	Seuils comportementaux, par organisation
En combien de jours une vulnérabilité critique doit-elle être corrigée ?	Le RSSI, avec la DSI	Délais de remédiation par criticité
Quel chemin d'attaque est le plus préoccupant ?	Le RSSI	Pondérations du calcul de chemins
Quelle détection activer, et avec quel ajustement ?	Le RSSI	Adoption depuis le catalogue, avec traçabilité de l'écart

Aucune de ces quatre décisions ne demande une livraison, un ticket chez l'éditeur ou une fenêtre de maintenance. Une politique de sécurité qui exige une montée de version pour changer un seuil n'est pas une politique : c'est une demande d'évolution.

Pensée pour l'analyste, lisible par le comité

Le quotidien de l'analyste

Alertes, cas, incidents, actifs, vulnérabilités, chemins d'attaque. L'alerte porte déjà le contexte de l'actif : criticité, exposition, dépendances, vulnérabilités ouvertes.

La vue du responsable

Tableaux de bord, posture de conformité par référentiel, registre des risques, profil de risque de l'organisation. Les chiffres viennent des mêmes données que les écrans d'analyse.

L'assistant d'investigation

Une question en langage naturel — « quels actifs exposés portent une vulnérabilité exploitée ? » — et la plateforme interroge ses propres données pour répondre. Optionnel et désactivable.

Bilingue

interface en français et en anglais, extensible

Rôles

ce qui s'affiche suit les habilitations, écran par écran

Web

aucun client lourd à déployer sur les postes

Où en est le projet, et où il va

HORIZON	CONTENU	ÉTAT
Socle et chaîne Ingestion, détection, réponse, audit, conformité, interface	Les 25 domaines, la chaîne continue, le catalogue signé, le paramétrage	Opérationnel, démontrable aujourd'hui
Connecteurs natifs Sources du client sans développement	Annuaire, pare-feu, cloud public, postes de travail	Prochaine étape
Mesure en charge Les indicateurs sur volume réel	Délai de détection, délai de réponse, débit d'ingestion, tenue en charge	Premier livrable d'un pilote
Industrialisation Exploitation à grande échelle	Haute disponibilité, reprise après sinistre, regroupement des composants	Planifié

Notre position sur les chiffres. Nous ne citons pas de délai de détection moyen tant que nous ne l'avons pas mesuré sur un volume réel. C'est le premier livrable que nous proposons dans un pilote — chez vous, sur vos données, avec vos équipes.

Comment cela se met en place

1 • Atelier de cadrage

Le périmètre du pilote, les sources à raccorder, les référentiels à suivre. Une journée.

Semaine 1

2 • Installation

Sur votre infrastructure, avec vos équipes. Durcissement, clés propres, contrôle de mise en service.

Semaine 2

3 • Raccordement

Les premières sources, l'inventaire d'actifs, le catalogue de détection adopté et ajusté avec le RSSI.

Semaines 3 à 6

4 • Mesure

Les indicateurs sur vos volumes, et la revue de conformité sur votre référentiel. Le bilan du pilote.

Semaines 7 et 8

Ce que nous apportons

La plateforme, le catalogue de détection, la documentation et l'accompagnement du cadrage à la mesure.

Ce que l'intégrateur apporte

La connaissance du système d'information du client, le raccordement des sources et l'exploitation dans la durée.

Une plateforme, quatre promesses

- **Voir en un seul endroit.** Vingt-cinq domaines qui partagent le même inventaire d'actifs, le même modèle d'identité et le même journal.
- **Réagir sans rupture.** De l'événement au confinement et à sa preuve, sans recopie d'un outil à l'autre — et le délai est mesuré.
- **Prouver en continu.** DNSSI, loi 09-08, PCI DSS, SWIFT CSP, ISO 27001, et le référentiel que vous apportez.
- **Rester chez vous.** Vos données sur votre infrastructure, sans flux sortant obligatoire ni dépendance étrangère.

La prochaine étape que nous proposons : un pilote de huit semaines sur un périmètre restreint, chez vous, avec la mesure de vos propres indicateurs comme livrable final. Et d'ici là, une démonstration de vingt minutes où une attaque traverse la plateforme devant vous.